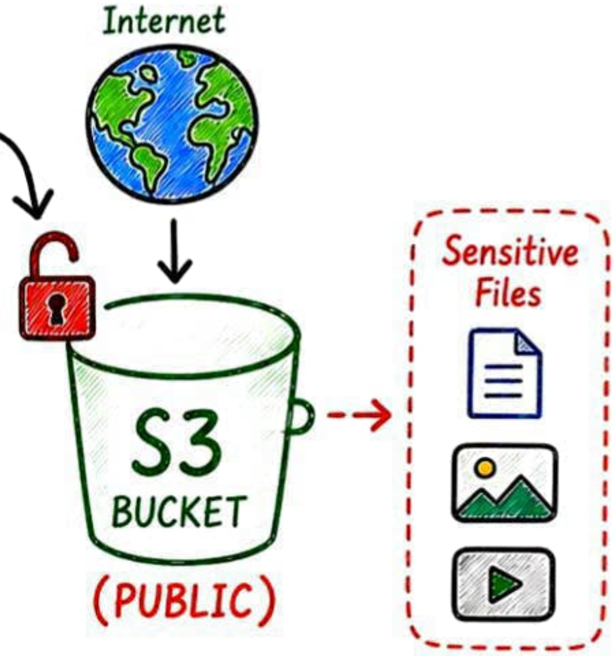
YOUR PRODUCTION S3 BUCKET IS PUBLIC!

Sensitive customer files are exposed to the world.

WHAT WOULD YOU CHECK FIRST?



PUBLIC ACCESS = SECURITY RISK

INTRODUCING

AMAZON S3 SECURITY

Secure your S3 bucket, before securing your application.

HOW S3 ACCESS ACTUALLY WORKS

Access to your S3 bucket is controlled by **multiple policies and settings**.

1. IAM POLICY

What permissions does this user/role have?

2. BUCKET POLICY

Who can access this bucket and what can they do?

3. BLOCK PUBLIC ACCESS

Prevents the bucket from becoming public accidentally.

4. ACL (ACCESS CONTROL LIST)

Legacy mechanism to control object-level permissions.
(Use with caution)

Final access is the **combination** of all applicable policies and controls.

IMPORTANT:

- An explicit **DENY** in any policy overrides all **ALLOW**.
- Keep your S3 bucket **private** by default.

S3 BLOCK PUBLIC ACCESS

Your first and most important line of defense against accidental public exposure.

ENABLE ALL FOUR SETTINGS

1. **Block new public ACLs**
   Prevents new objects from having public ACLs.
2. **Ignore public ACLs**
   Ignores public ACLs on existing objects.
3. **Block new public bucket policies**
   Prevents bucket policies that allow public access.
4. **Restrict public bucket policies**
   Restricts bucket policies that allow public access.

WITHOUT BLOCK PUBLIC ACCESS

WITH BLOCK PUBLIC ACCESS

Best Practice:
For most private production buckets, enable all four settings.

RESULT

BLOCK PUBLIC ACCESS IS YOUR FIRST SHIELD.
ENABLE IT. VERIFY IT. KEEP IT ON.

S3 ENCRYPTION

Encrypt your data at rest to protect it even if someone gains access to the bucket.

SSE-S3

(S3 MANAGED KEYS)

- S3 manages the encryption keys
- Simple and easy to use
- Automatic encryption
- No extra cost for key management
- Ideal for most general use cases

SSE-KMS

(KMS MANAGED KEYS)

- AWS KMS manages the keys
- Fine-grained key permissions
- CloudTrail visibility for KMS API activity
- More control and compliance
- Ideal for sensitive and regulated data

HOW IT WORKS (DATA AT REST)

KEY TAKEAWAY

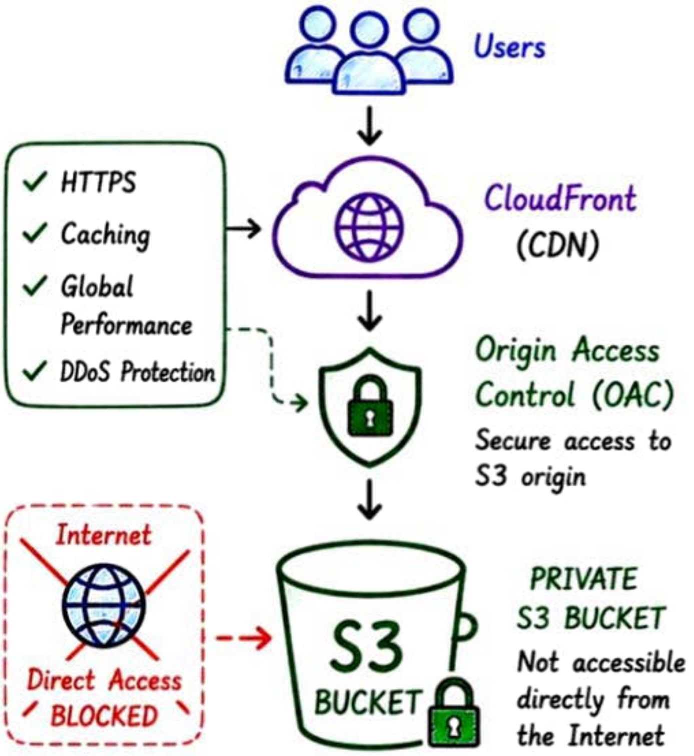
- ☑ Encrypt all sensitive data at rest.
- ☑ Use SSE-S3 for simplicity.
- ☑ Use SSE-KMS for more control.

INTERVIEW TIP

If the question involves control, audit, compliance or key permissions → SSE-KMS is usually the better answer.

SECURE S3 PRODUCTION ARCHITECTURE

Don't make your S3 bucket public just to serve files to users!



WHY THIS ARCHITECTURE?

- S3 bucket remains private.
- Only CloudFront can access S3 using OAC.
- Better performance with caching.
- Secure content delivery globally.
- Reduced origin load and cost optimization.

KEY POINT

Use CloudFront + OAC to serve files from a PRIVATE S3 bucket securely.

Keep your S3 private. Use the right layers of security.

AWS INTERVIEW CHEAT SHEET

HOW WOULD YOU SECURE A PRODUCTION S3 BUCKET?

Follow these best practices to keep your data safe, private and compliant.

1 Enable S3 Block Public Access

- Turn ON all four settings.
  This is your first line of defense.

2 Use Least-Privilege Access

- Use IAM roles/users with minimal permissions.
- Use bucket policies to control access.

3 Encrypt Data

- Use SSE-S3 for simplicity.
- Use SSE-KMS for more control and auditability.

4 Enforce Secure Transport (HTTPS)

- Deny non-HTTPS requests using bucket policy.

5 Enable Logging & Monitoring

- Enable S3 Server Access Logging.
- Enable CloudTrail for API activity.
- Use Amazon GuardDuty for threat detection.

6 Use CloudFront + OAC

- Keep S3 bucket private.
- Serve content via CloudFront using Origin Access Control (OAC).

INTERVIEW QUESTION ?

You discover that sensitive files in an S3 bucket are publicly accessible.
What would you do?

BEST ANSWER FRAMEWORK

- ☑ Immediately remove public access.
- ☑ Check & enable S3 Block Public Access (all four).
- ☑ Review bucket policies, ACLs and IAM permissions.
- ☑ Enable encryption for data at rest.
- ☑ Enable logging/auditing and monitoring.
- ☑ Use CloudFront + OAC for secure content delivery.

REMEMBER

- Keep S3 PRIVATE
- Block PUBLIC ACCESS
- Encrypt SENSITIVE DATA
- Least PRIVILEGE ACCESS
- Log, Monitor & Audit

KEY TAKEAWAY

S3 is powerful, but security is your responsibility.
Secure it today, sleep peacefully tomorrow.

★ SAVE THIS FOR YOUR AWS INTERVIEWS!